



SECURING THE LLM CHATBOT

- THREATS AND MITIGATION

Ahmed Mahfooz Ali Khan alaa23@student.bth.se (PA2562)

Sai Nikhil Sakhetapuram sask23@student.bth.se (PA2562)

Syed Tafazzul Hazqueel tasy23@student.bth.se (PA2562)

Surya Gujja sugu23@student.bth.se (PA2562)

Rajeev Varma Kanna raka23@student.bth.se (PA2562)

ABSTRACT:

This report highlights the hypercritical need for securing LLM chatbot system to protect against potential threats. In this report, we have discovered important security flaws that make system more vulnerable to prompt injections, data breaches, insecure output handing and malicious inquiries. To address these issues, the report proposes comprehensive mitigation strategies that incorporates of user authentications, encryption, security, regular audits and monitoring. Hence it is imperative to implement the measures for safeguarding the LLM and ensuring long-term success.

INTRODUCTION:

The integration of Large Language Models (LLMs) in chatbot systems has undoubtedly enhanced the capabilities of natural language processing and interaction. However, with this advancement comes new set of potential threats that organizations must be vigilant about to ensure the security and integrity of their systems. This comprehensive overview outlines key vulnerabilities associated with LLM chatbots and provides mitigation recommendations to address these concerns.

POTENTIAL THREATS

The potential threats associated to the LLM chatbot are as follows:

- **INSECURE OUTPUT HANDLING:** It is a security vulnerability which has been stated by OWASP that occurs when the output generated by a large language model (LLM) is not properly reviewed and validated before being used. This can lead to serious security consequences, as malicious actors can potentially exploit this flaw to gain unauthorized access to systems or data.

Potential consequences of Insecure Output Handling:

Code Injection: Malicious code can be embedded within the LLM's output, which can then be executed by the system, potentially leading to data breaches or system compromise.

Cross-Site Scripting (XSS): LLM-generated scripts can be injected into web pages, allowing attackers to steal user data, redirect users to malicious websites, or deface web pages.

Remote Code Execution: Insecure file handling or unvalidated input in dynamic code execution scenarios can allow attackers to upload and execute malicious code on the server. This may result in complete compromise of the system, unauthorized access, or the theft of sensitive data.

- **PROMPT INJECTIONS:** Prompt Injection is a security vulnerability that affects certain AI models, particularly large language models (LLMs) like me. It essentially involves manipulating the prompts that users provide to an LLM in order to trick it into performing unintended actions. Let me explain it in more detail:
 - OWASP ranks prompt injection attacks as the **most critical vulnerability** observed in language models.
 - Manipulating LLMs via crafted inputs can lead to unauthorized access, data breaches, and compromised decision-making.
 - Organizations using LLMs need to be aware of this risk and implement controls to prevent exploitation.

How Prompt injection occur in a LLM:

Data breaches: Attackers can trick the LLM into revealing sensitive information like passwords or confidential data.

Unauthorized actions: The LLM might be manipulated to perform actions it wasn't designed for, like deleting files or changing system settings.

- **SUPPLY CHAIN VULNERABILITIES:** Supply chain vulnerabilities refer to weaknesses or points of exposure in the interconnected network of processes, systems, and organizations that collectively contribute to the production and delivery of goods or services. The supply chain encompasses all the stages involved in bringing a product or service from the initial conception to the end consumer, including raw material extraction, manufacturing, distribution, retail, and more. The various components involved in an LLM's development and operation, from training data and pre-trained models to plugins and third-party components, can all be susceptible to vulnerabilities. These weaknesses can be exploited to manipulate the LLM's behaviour, potentially leading to biased or inaccurate outputs, security breaches, and even system failures. Depending upon compromised components, services or datasets undermine system integrity, causing data breaches and system failures.

Here are some potential threats related to supply chain vulnerabilities in LLMs:

Bias and misinformation: Biases present in the training data may be unintentionally perpetuated, leading to biased or unfair outputs leads to LLMs which might generate content that reflects or amplifies existing biases, potentially reinforcing stereotypes or discriminatory behaviour.

Security breaches: Exploitable weaknesses can grant unauthorized access to sensitive information or disrupt LLM operations, compromising security.

System failures: In severe cases, vulnerabilities can cause complete system failures, rendering the LLM inoperable

- **EXCESSIVE AGENCY:** Excessive agency refers to large language models making decisions that go beyond their intended scope and may cause harm. llms are frequently linked to other systems and can perform operations in those systems automatically based on user input. this makes the llm system an indirect attack vector for other systems; if the llm is given too much autonomy or agency to commit actions in other systems, it may be able to circumvent standard protections. penetration testers should ensure that the llm system is subject to the appropriate security restrictions on all systems with which it interacts, particularly those that allow the llm to perform automated changes.

How do they work:

Excessive Functionality/Permissions: Granting an LLM access to functionalities or permissions beyond its intended use case increases the risk of unintended actions.

Lack of Input Filtering: If not equipped to filter out misleading or malicious prompts, the LLM might generate harmful outputs based on them.

- **MISINFORMATION AND DISINFORMATION:** Misinformation can occur in the setting of LLM chatbot when the model generates responses factually incorrect. This can happen because of biases in the training data, misinterpretation of the context, or in unintentional errors in language problems. On the other hand disinformation could occur when malicious actors deliberately alter the model to provide misleading material that spreads incorrect information .

MITIGATION RECOMMENDATIONS:

INSECURE OUTPUT HANDLING:

- **Validate and Sanitize:** Just like user input, LLM outputs should be thoroughly validated and sanitized to remove any malicious code or harmful elements before being used.
- **Treat LLM Output as Untrusted Data:** Never assume that the LLM's output is accurate or safe. Implement appropriate security measures to handle it cautiously.
- **Output Encoding:** To neutralize or sanitize user-generated content. Use Content Security Policy (CSP) headers to control script execution.

PROMPT INJECTIONS:

- **Input Validation:** Systems can be designed to check prompts for suspicious patterns or keywords that might indicate an attack.
- **Model Hardening:** During training, expose the LLM to a variety of attack prompts to strengthen its resistance to manipulation. Implement internal filters within the LLM to detect and eliminate suspicious prompt elements.
- **Prompt Remediation:** Develop procedures to address detected prompt injection attempts, such as quarantining the prompt or taking corrective actions on the LLM. Establish mechanisms to alert security personnel and log any suspicious activity related to prompt injection attempts.

DATA BREACHES:

- **Robust encryption:** Strong encryption algorithms can be used to safeguard data both in transit and at rest.
- **Monitor performance:** Continuously monitor the chatbot for suspicious activity and update security settings as necessary.
- **Data minimization:** Only gather the information required for the chatbot to work; avoid storing sensitive information unless it is necessary
- **Regular data security audits:** By conducting routine audits Proactively identify and address vulnerabilities in your data security procedures.

SUPPLY CHAIN VULNERABILITIES:

- **Data and supplier vetting:** Ensure training data is reliable and unbiased by carefully vetting data sources and suppliers. Thoroughly evaluate and use only reputable plugins and third-party components for LLM systems.
- **Monitoring and Transparency:** Continuously monitor the LLM for vulnerabilities and conduct "adversarial testing" to identify potential weaknesses. Promote transparency in LLM development and hold stakeholders accountable for responsible use of the technology.
- **Patch management:** Regularly update and patch all software components involved in the LLM system to address identified vulnerabilities.

EXCESSIVE AGENCY:

- **Clearly Define Purpose and Scope:** Clearly define the intended use case and functionalities of the LLM to avoid exceeding its boundaries.
- **Robust Input Validation:** Implement mechanisms to filter out misleading, malicious, or nonsensical prompts before the LLM processes them.
- **Continuous Monitoring and Human Oversight:** Continuously monitor the LLM's outputs for potential issues and maintain human oversight to intervene if necessary.
- **Regular Testing and Evaluation:** Regularly test and evaluate the LLM to identify and address potential biases or vulnerabilities that could lead to excessive agency.

MISINFORMATION AND DISINFORMATION:

- **Filtering and content moderation:** Implement content filtering mechanisms to recognize and remove false information. Use predefined rules, heuristics, or machine learning models to flag or block content that raises concerns.
- **Source verification:** Evaluate the sources of information's credibility. Give consumers details about the information's origins and exhort them to confirm facts from reputable and reliable trustworthy sources.
- **User feedback system:** Establish a framework for user feedback so that people may report false information. Utilize this input to fix any possible problems, address potential issues and enhance the chatbot's accuracy of responses.
- **Transparency and explainable:** Make the chatbot's decision-making process more transparent and understandable. Give justification for the sources of information or reasoning behind responses, helping users better evaluate the reliability of the information.

CONCLUSION:

The integration of large language models (LLMs) into chatbot systems introduces notable security vulnerabilities, including insecure output handling, prompt injections, supply chain vulnerabilities, excessive agency, and misinformation/disinformation. Addressing these threats requires a multifaceted approach. For instance, mitigating insecure output handling involves validating and sanitizing LLM outputs, treating them as untrusted data, and employing encoding techniques to neutralize potential security risks. Additionally, countering prompt injections requires measures such as input validation, model hardening during training, and prompt remediation procedures, coupled with continuous monitoring and user feedback systems.

To bolster overall security, organizations must implement robust encryption, monitor for suspicious activity, practice data minimization, and conduct regular security audits to prevent data breaches. Furthermore, efforts to combat misinformation and disinformation involve implementing content filtering, source verification, user feedback frameworks, and enhancing the transparency of the chatbot's decision-making process. It is crucial to navigate their use responsibly and with a thorough understanding of the associated risks. By implementing robust security measures and promoting transparency and accountability, we can harness the benefits of LLMs while minimizing potential threats. By adopting these mitigation strategies, organizations can navigate the complexities of LLM-based chatbot systems and provide users with a secure and reliable conversational experience.

REFERENCES:

1. "OWASP Top 10 for Large Language Model Applications." [Online]. Available: <https://owasp.org/www-project-top-10-for-large-language-model-applications/>
2. OWASP Application Security Verification Standard (ASVS) - Version 4.0
3. "Top Security Risks of Large Language Models." [Online]. Available: <https://deepchecks.com/top-security-risks-of-large-language-models/>
4. Malik Almaliki. 2019. Online Misinformation Spread: A Systematic Literature Map. In Proceedings of the 2019 3rd International Conference on Information System and Data Mining (Houston, TX, USA) (ICISDM 2019). Association for Computing Machinery, New York, NY, USA, 171-178. <https://doi.org/10.1145/3325917.3325938>
5. "Exploring the risk of using large language models." [Online]. Available: <https://brightsec.com/whitepapers/exploring-the-security-risks-of-using-large-language-models/#:~:text=A%20security%20misconfiguration%20may%20leave,%2C%20modify%2C%20or%20delete%20data.>
6. Buchanan B, Lohn A, Musser M, Sedova K. Truth, Lies, and Automation: How Language Models Could Change Disinformation. Washington, DC: Centre for Security and Emerging Technology. (2021).
7. Kreps S, McCain RM, Brundage M. All the news that's fit to fabricate: AI-generated text as a tool of media misinformation. J Exp Polit Sci. (2022) 9:104–17. [doi: 10.1017/XPS.2020.37](https://doi.org/10.1017/XPS.2020.37)
8. OWASP Guide to Input Validation-OWASP Input Validation
9. ISO/IEC 27001:2013 - Information technology — Security techniques — Information security management systems — Requirements.
10. ISO/IEC 27032:2012 - Information technology — Security techniques — Guidelines for cybersecurity.
11. Brundage, M., et al. (2018). The Malicious Use of Artificial Intelligence: Forecasting, Prevention, and Mitigation. arXiv preprint arXiv:1802.07228.
12. European Commission. (2019). "Ethics Guidelines for Trustworthy AI." High-Level Expert Group on Artificial Intelligence.
13. Verizon Data Breach Investigations Report (DBIR) – 2021
14. Jiawei Zhou, Yixuan Zhang, Qianni Luo, Andrea G Parker, and Munmun De Choudhury. 2023. Synthetic Lies: Understanding AI-Generated Misinformation and Evaluating Algorithmic and Human Solutions. In *Proceedings of the 2023 CHI Conference on Human Factors in Computing Systems (CHI '23)*, April 23–28, 2023, Hamburg, Germany. ACM, New York, NY, USA 20 Pages. <https://doi.org/10.1145/3544548.3581318>